UNLOQ SOLUTIONS LTD

DIBS Platform Programme

Secure Vault & Multi-Tenant VPC Infrastructure

Phase 4 — Documentation Pack

Version	1.1
Date	March 2026
Author	Sourav / Unloq Platform Team
Classification	Internal — Confidential
Status	Final

© 2026 Unloq Solutions LtdInternal — Confidential

1. Architecture Overview

The DIBS Vault is a secure, multi-tenant document upload platform built on AWS. Each client (tenant) gets a branded, isolated environment via their own URL. All data stays in the UK (eu-west-2 London region).

1.1 AWS Services Used

Service	What It Does	How It Is Configured
CloudFront	Delivers the website fast and securely over HTTPS	vault.unloq.co, SSL certificate, connects to S3
S3	Stores all uploaded files	Encrypted, versioned, files separated by tenant folder
API Gateway	The door to all backend functions	18 routes, requires login token to access
Lambda	Runs all business logic	18 functions, Python, runs inside private network
Cognito	Handles login and user accounts	MFA required, groups per tenant, JWT tokens
DynamoDB	Database for tenant and user data	2 tables: tenants and registrations
KMS	Encrypts all stored files	One encryption key, rotates automatically yearly
SES	Sends all emails	noreply@unloq.co, verified domain
SNS	Sends notifications between services	File-ready events for future DIBS pipeline
VPC	Private network — keeps traffic off public internet	London region, 2 availability zones
Route53	DNS — points vault.unloq.co to the right place	Alias to CloudFront
CloudTrail	Records every action taken in AWS	Full audit log, queryable
GuardDuty	Detects threats and unusual activity	Alerts sent to Slack + email
EventBridge	Runs scheduled tasks	48-hour escalation timer for pending approvals

1.2 Multi-Tenant Isolation — Four Security Layers

Even if one security layer fails, three others still prevent any cross-tenant data access:

Layer	How It Works	What Happens If It Fails

1 — URL Routing	Invalid tenant slug returns a 404 error page	Layers 2, 3, 4 still block access
2 — Email Domain	Only emails matching tenant's domain can register	Layers 3 and 4 still block access
3 — Login Token	Token contains tenant ID — backend rejects mismatches	Layer 4 still blocks access
4 — IAM Boundary	AWS role is locked to tenant's S3 folder — cannot escape	Final hard stop — no AWS action possible

1.3 Data Residency

UK Data Residency — eu-west-2 (London)
All data (files, user records, audit logs) is stored exclusively in the AWS London region.
No data is replicated to other countries.
Compliant with UK GDPR data residency requirements.

2. User Flows

Three types of user interact with the platform, each with a distinct flow:

User Type	Who They Are	What They Can Do
Unloq Admin	Unloq internal staff (e.g. Satyen)	Create tenants, create first admin accounts, view everything
Tenant Admin	Client IT contact (e.g. Taylor Wimpey IT Manager)	Approve registrations, add colleagues, manage their team
Employee	Regular client staff	Register, verify email, upload files after approval

2.1 New Tenant Onboarding — Step by Step

Target: New tenant live in under 30 minutes
All steps done through the website — no command line or AWS Console needed.
Self-registration means no manual account creation for each employee.

Step	Action	What Happens	Who
1	Unloq admin logs in to vault.unloq.co/admin	Sees Unloq Admin dashboard with all tenants	Unloq team
2	Creates new tenant	Fills company name, slug, email domains. AWS resources created automatically.	Unloq team
3	Creates first admin user	Enters admin name and email. Clicks Create Admin.	Unloq team
4	Welcome email sent	Email with login URL, email address, and temporary password sent automatically	System
5	Admin logs in and sets password	Visits vault.unloq.co/slug. Changes temporary password on first login.	Tenant admin
6	Admin completes profile	Enters name and job title. Step 1 of 2.	Tenant admin
7	Admin completes company setup	Enters company name, industry, size. Uploads logo. Step 2 of 2.	Tenant admin
8	Admin reaches dashboard	vault.unloq.co/slug/admin — can now manage team registrations	Tenant admin
9	Tenant shows Active	Status updated in Unloq admin dashboard	System

2.2 Employee Self-Registration — Step by Step

Step	Action	What Happens	Who
1	Visit vault.unloq.co/slug	Branded login page loads with company logo and colours	Employee
2	Click Apply for Access	Registration form opens	Employee
3	Fill in form	Name, work email, job title, reason. Email domain checked against allowed list.	Employee
4	Submit	Record created. Verification email sent. Link expires in 24 hours.	System
5	Click verification link	Email verified. Status moves to Pending Approval. Admin notified.	Employee
6a	Admin approves	Cognito account created. Welcome email with temp password sent.	Tenant admin
6b	Admin rejects	Rejection email sent with reason. No account created.	Tenant admin
7	Employee logs in	Sets new password. Sets up MFA on first login.	Employee
8	Employee uploads files	Files encrypted with KMS key. Stored in tenant's private folder.	Employee

2.3 Registration Status Flow

Every registration moves through these statuses in order:

Status	Plain English Meaning	How Long It Lasts
email_pending	Registered but email not yet verified	Up to 24 hours (link expires)
pending_approval	Email verified, waiting for admin decision	Up to 48 hours (escalation fires)
active	Approved — can log in and upload files	Indefinitely
rejected	Declined by admin	Record kept 90 days, then deleted
expired	Did not click verification link in time	Auto-deleted after 7 days
invalidated	Too many failed verification attempts	Must contact admin to re-register

© 2026 Unloq Solutions LtdInternal — Confidential

3. Tenant Onboarding Runbook

3.1 Before You Start — Checklist

Item Needed	Where to Get It
Client company name and preferred URL slug (e.g. taylorwimpey)	From client
Client email domain (e.g. taylorwimpey.co.uk)	From client
Name and work email of first admin contact at the client	From client
Client logo file — PNG or SVG, under 2MB (optional)	From client
Industry, company size, website (optional)	From client
Your Unloq admin login for vault.unloq.co/admin	Unloq internal

3.2 Step-by-Step Guide

Step 1 — Create the Tenant (5 minutes)

1. Log in to vault.unloq.co/admin
2. Click + New Tenant in the top right
3. Fill in the form and click Create Tenant

Slug Rules — Important
Use lowercase letters and numbers only — no spaces, no hyphens.
CORRECT: taylorwimpey WRONG: taylor-wimpey or Taylor Wimpey
The slug becomes the permanent URL: vault.unloq.co/taylorwimpey

Step 2 — Create Admin Account (2 minutes)

4. From the tenant list, click View on the new tenant
5. Scroll to the Tenant Admin section
6. Click + Create Admin User
7. Enter the admin's name, work email, and job title
8. Click Create Admin and Send Welcome Email

Step 3 — Verify Email Delivery (1 minute)

9. Confirm the client admin received the welcome email from noreply@unloq.co
10. If not received: check spam folder, allow 5 minutes

Step 4 — Client Admin Completes Setup (10 minutes)

© 2026 Unloq Solutions LtdInternal — Confidential

The client admin does this themselves after receiving the email:

11. Click Log In and Complete Setup in the welcome email
12. Enter temporary password, then set a new one (12+ characters)
13. Complete Profile: name and job title
14. Complete Company Setup: name, industry, size, optional logo
15. Click Complete Setup

Step 5 — Confirm Everything is Working (2 minutes)

16. Check vault.unloq.co/admin — tenant should show Active status
17. Ask the client admin to confirm they can see their admin dashboard
18. Send the client their vault URL and self-registration instructions

3.3 Send to Client After Go-Live

Subject: Your Secure Vault is Ready — vault.unloq.co/[slug]

Hi [Admin Name],
Your secure document vault is now live.
Your vault URL: https://vault.unloq.co/[slug]

Your team members can request access by:

- Visiting the URL above
- Clicking Apply for Access
- Filling in the form with their work email
- Clicking the verification link in their email
- Waiting for your approval in the admin panel

You will be notified by email when someone requests access. Questions? Contact support@unloq.co

4. Client Admin Guide

This guide is for the person at your organisation who manages vault access for your team. No technical knowledge is required.

4.1 Getting to Your Admin Dashboard

19. Go to your vault URL: vault.unloq.co/[your company slug]
20. Log in with your admin email and password
21. You will land on the admin dashboard automatically

> **Tip**
> Bookmark vault.unloq.co/[slug]/admin for quick access to the admin panel in future.

4.2 Approving and Rejecting Access Requests

When a team member registers, you receive a notification by email. Here is how to action it:

To Approve a Request:

22. Click the Pending Approvals tab in your admin dashboard
23. Review the request — check the person's name, email, job title, and reason
24. Click the green Approve button
25. Their account is created and they receive a welcome email automatically

To Reject a Request:

26. Click Reject next to the request
27. Enter a reason (this is included in the rejection email to the applicant)
28. Click Confirm Reject

> **48-Hour Rule**
> Please action all requests within 48 hours.
> If not actioned in time, the Unloq team will receive an alert.

4.3 Adding Colleagues Directly

You can add colleagues directly — they skip registration and receive a welcome email with login details.

Add One Person:

29. Click + Add Colleague tab
30. Fill in name, email, job title, role, and level

© 2026 Unloq Solutions LtdInternal — Confidential

31. Click Add Colleague — they receive a welcome email immediately

Add Multiple People at Once (Bulk Upload):

32. Click the Bulk Upload tab
33. Click Download CSV Template
34. Open the template in Excel and fill in your colleagues' details
35. Save as CSV and upload the file
36. Results show how many were added and any errors

CSV Column	Required	Example Value
first_name	Yes	Jane
middle_name	No	Louise
last_name	Yes	Smith
email	Yes	jane.smith@company.com
job_title	Yes	Project Manager
role	Yes	employee or admin
level	Yes	junior / mid / senior / lead / director / c_level

4.4 Understanding Status Badges

Badge	What It Means
Active (Green)	Account is active — person can log in and upload files
Pending (Yellow)	Email verified, waiting for your approval
Verifying (Blue)	Registered but has not yet clicked the verification email link
Rejected (Red)	Access was declined — no account exists for this person

© 2026 Unloq Solutions LtdInternal — Confidential

5. Architecture Decision Record (ADR) Log

This log records the key technical decisions made during the DIBS Vault build. It explains WHY things were built the way they were — useful for anyone joining the project later or questioning a design choice.

ADR-001 — Single S3 Bucket with Per-Tenant Folders	
Context	Files need to be stored for multiple tenants with strict separation.
Decision	One S3 bucket with per-tenant folder structure and IAM roles scoped to that folder.
Rationale	Simpler to manage, lower cost, sufficient isolation. Per-tenant buckets add complexity without security benefit at this scale.
Consequences	Works well for 3-20 tenants. Can migrate to S3 Access Points later if needed.

ADR-002 — AWS Cognito for Login (Not Auth0 or Custom)	
Context	The platform needs login with MFA, tokens, and group-based access.
Decision	AWS Cognito User Pool with MFA required and a Lambda to inject custom claims into tokens.
Rationale	Native AWS, no third-party cost or dependency, direct integration with API Gateway and IAM.
Consequences	Cognito hosted UI has limited styling. External SSO (Google, Microsoft) migration path exists.

ADR-003 — Path-Based URLs (Not Subdomains)	
Context	Each tenant needs a branded bookmarkable URL.
Decision	vault.unloq.co/slug for each tenant — single website, tenant looked up from registry.
Rationale	One SSL certificate, one CloudFront distribution. Subdomain approach needs per-tenant DNS and wildcard cert.
Consequences	Simpler certificate management. Branding applied dynamically by the website.

ADR-004 — Self-Registration with Human Approval	
Context	Client employees need vault access but Unloq cannot manually create every account.
Decision	Employees self-register, verify email, then a human approves before the account is created.
Rationale	Removes Unloq from every user creation. Maintains security gate. Mirrors the DIBS AI approval pattern.
Consequences	Admin overhead for approvers. 48-hour escalation timer prevents requests going stale.

© 2026 Unloq Solutions LtdInternal — Confidential

ADR-005 — Terraform for All Infrastructure	
Context	Infrastructure needs to be repeatable and auditable without manual steps.
Decision	Every AWS resource defined in Terraform. Zero console-only configuration. State stored in S3.
Rationale	New tenant in under 15 minutes via one command. Full audit trail in git. Disaster recovery by re-running.
Consequences	All changes must go through Terraform. Console changes will be overwritten on next run.

ADR-006 — One KMS Encryption Key for All Tenants	
Context	Files must be encrypted. Some clients may want their own key.
Decision	Single KMS key for all tenants initially. Automatic annual rotation.
Rationale	Dramatically simpler to manage. Per-tenant keys require separate policies and operational complexity.
Consequences	If a tenant requires their own key (compliance), this is documented as a future migration path.

ADR-007 — Lambda Functions in Private Network	
Context	Lambda functions need to access AWS services securely.
Decision	All 18 Lambda functions run inside the private VPC with VPC Endpoints for S3, KMS, DynamoDB.
Rationale	Traffic to AWS services never touches the public internet. Meets enterprise security requirements.
Consequences	Slightly higher startup times. VPC configuration required on every Lambda.

ADR-008 — eu-west-2 London as the Only Region	
Context	UK clients require data to remain in the UK.
Decision	All resources deployed in eu-west-2. No cross-region replication.
Rationale	UK GDPR compliance. Taylor Wimpey and other UK clients have contractual requirements.
Consequences	International clients needing local data residency would require separate regional deployments.

© 2026 Unloq Solutions LtdInternal — Confidential

6. Monthly Cost Projection — 5 Tenant Baseline

This shows the estimated monthly AWS bill for 5 active tenants with moderate usage. All costs are in GBP, based on eu-west-2 (London) pricing as of Q1 2026.

Assumptions Used

5 active tenants, average 50 users each (250 total users)
100 file uploads per tenant per month (500 total) — average file size 5MB
Total stored data after 12 months: approximately 30GB
50,000 Lambda function calls per month across all 18 functions
100,000 API Gateway requests per month

6.1 Breakdown by AWS Service

AWS Service	Est. Usage	Monthly Cost	Notes
NAT Gateway	730 hrs + 10GB	**GBP 28-35**	Largest fixed cost. One per availability zone.
CloudFront	50GB data transfer	**GBP 3-5**	First 1TB per month is very cheap.
S3 Storage	30GB	**GBP 1-2**	Lifecycle rules move old files to cheaper storage automatically.
S3 Requests	500K requests	**GBP 1-2**	File upload and download requests.
API Gateway	100K requests	**GBP 1**	HTTP API pricing is very low.
Lambda	50K invocations	**Under GBP 1**	Well within free tier at this scale.
DynamoDB	On-demand reads/writes	**Under GBP 1**	Very low cost at current data volumes.
Cognito	250 monthly active users	**Under GBP 1**	First 50,000 users per month are free.
KMS	1 key + API calls	**GBP 1**	One key plus approximately 10,000 API calls per month.
SES Email	1,000 emails/month	**Under GBP 1**	10p per 1,000 emails sent.
CloudWatch	Logs and metrics	**GBP 2-5**	Log ingestion and 90-day retention.
CloudTrail	Audit events	**Under GBP 1**	First copy of management events is free.
GuardDuty	Threat detection	**GBP 5-10**	Cost based on data volume analysed.

© 2026 Unloq Solutions LtdInternal — Confidential

EventBridge	Scheduled escalations	**Under GBP 1**	Minimal cost for timer rules.
TOTAL MONTHLY ESTIMATE		**GBP 43-64**	Approximately GBP 55 per month at mid estimate

6.2 How Costs Grow with More Tenants

Scale	Number of Tenants	Approx. Users	Est. Monthly Cost
Current (baseline)	3-5	250	GBP 43-64
Growth	10	500	GBP 70-100
Scaled	25	1,250	GBP 130-180
Enterprise	50	2,500	GBP 220-300

Key Cost Driver

NAT Gateway is the dominant fixed cost at GBP 28-35 per month regardless of usage.

All other costs scale proportionally with usage — more tenants and files means higher costs.

At 50+ tenants: add VPC Endpoints for all services to reduce NAT Gateway traffic.

S3 lifecycle rules (files move to cheaper storage after 90 days) significantly reduce storage cost at scale.

© 2026 Unloq Solutions LtdInternal — Confidential

7. Security Checklist

This checklist must be completed before handling real client data.

Network Security			
	All Lambda functions run inside private VPC subnets	**Done**	Sourav
	VPC Endpoints for S3, KMS, DynamoDB — traffic off public internet	**Done**	Sourav
	Security groups with restrictive defaults and explicit allow-lists	**Done**	Sourav
	VPC Flow Logs enabled — 90-day retention	**Done**	Sourav
Storage Security			
	S3 Block All Public Access enabled	**Done**	Sourav
	S3 versioning enabled — files recoverable	**Done**	Sourav
	S3 default encryption with KMS key	**Done**	Sourav
	S3 bucket policy: deny unencrypted uploads, deny non-HTTPS	**Done**	Sourav
	S3 lifecycle rules: IA after 90 days, Glacier after 365	**Done**	Sourav
Login and Access Security			
	MFA required for all users (authenticator app or SMS)	**Done**	Sourav
	Password policy: 12+ characters, mixed case, numbers, symbols	**Done**	Sourav
	Login tokens contain tenant ID — cross-tenant access rejected	**Done**	Sourav
	No account created until a human approves the registration	**Done**	Sourav
Encryption			
	KMS key automatic annual rotation enabled	**Done**	Sourav
	All data encrypted in transit (HTTPS enforced)	**Done**	Sourav
	All data encrypted at rest (KMS)	**Done**	Sourav
Monitoring and Audit			
	CloudTrail S3 data events — every file access logged	**Done**	Sourav
	All Lambda functions have CloudWatch log groups	**Done**	Sourav
	GuardDuty threat detection enabled	**Done**	Sourav

© 2026 Unloq Solutions LtdInternal — Confidential

	Alarms: Lambda errors, API failures, S3 access denied	**Done**	Sourav
	48-hour escalation timer for pending registrations	**Done**	Sourav
Registration Security			
	Email domain restriction per tenant	**Done**	Sourav
	Rate limiting: max 10 registration attempts per tenant per hour	**Done**	Sourav
	Duplicate registration detection	**Done**	Sourav
	Verification tokens are hashed — raw token only in email	**Done**	Sourav
	Tokens single-use and expire after 24 hours	**Done**	Sourav
Remaining Actions			
	IAM Access Analyzer — review findings	**Pending**	Sourav
	Security Hub CIS benchmarks — resolve critical findings	**Pending**	Sourav
	ClamAV antivirus scanning implementation	**Pending — awaiting Satyen approval**	Sourav
	Least-privilege IAM audit before first real client data	**Pending**	Sourav
	Registration abuse testing — rate limits, domain restrictions	**Pending**	Sourav

© 2026 Unloq Solutions LtdInternal — Confidential

8. Incident Response Runbook

Quick reference for common issues.

8.1 User Cannot Log In

Check	What to Do
Account exists?	Search for the email in AWS Cognito User Pool (eu-west-2_c2TEDrKrq)
Account confirmed?	Status in Cognito must be CONFIRMED not FORCE_CHANGE_PASSWORD
Correct tenant URL?	User must visit vault.unloq.co/[their-company-slug] not a different tenant
MFA issue?	Admin can reset MFA for user in Cognito if they lost their authenticator app
Forgotten password?	Admin resets password in Cognito — user gets new temporary password

8.2 File Upload Not Working

Check	What to Do
File type blocked?	Check tenant config in DynamoDB — allowed_file_types field
File too large?	Default max is 100MB — check tenant config max_file_size_mb field
Lambda error?	Check CloudWatch logs: /aws/lambda/dibs-vault-dev-vault-presign
S3 permission?	Check IAM role has s3:PutObject on clients/[tenant-id]/* prefix
Encryption error?	Lambda role must have kms:GenerateDataKey on the vault KMS key

8.3 Verification Email Not Received

Check	What to Do
Spam folder?	Ask user to check spam. SES emails are occasionally filtered.
Email bounced?	Check SES console for bounce notifications on that email address
Can resend?	User can click Resend verification email — 24hr cooldown, max 5 resends
Registration exists?	Check DynamoDB unloq-vault-registrations table for the email

© 2026 Unloq Solutions LtdInternal — Confidential

8.4 AWS Console Quick Reference

Resource	Where to Find It
Cognito User Pool	AWS Console > Cognito > User Pools > eu-west-2_c2TEDrKrq
Tenant Registry	AWS Console > DynamoDB > Tables > unloq-tenant-registry
Registrations	AWS Console > DynamoDB > Tables > unloq-vault-registrations
S3 Files	AWS Console > S3 > unloq-vault-prod
Lambda Logs	AWS Console > CloudWatch > Log Groups > /aws/lambda/dibs-vault-dev-*
API Gateway	AWS Console > API Gateway > vault-api
Encryption Key	AWS Console > KMS > Customer managed keys > alias/unloq-vault-kms
Threat Detection	AWS Console > GuardDuty > Findings
Audit Log	AWS Console > CloudTrail > Event history

© 2026 Unloq Solutions LtdInternal — Confidential

9. Deferred Features — Awaiting Approval

9.1 ClamAV Antivirus Scanning

Status: Awaiting Satyen Approval
ClamAV antivirus scanning is required by the SOW.
Current state: files are checked by type and extension only — no virus scan.
Implementation needs EFS (Elastic File Storage) added to the infrastructure.
Estimated additional cost: GBP 5-15 per month.
Action required: Satyen to approve EFS addition, then Sourav implements.

Item	Detail
What ClamAV does	Scans every uploaded file for viruses and malware before it is stored
Approach	Lambda function reads ClamAV from an EFS mount — no Fargate or containers needed
Why not just Lambda?	ClamAV binary and virus definitions are over 200MB — too large for Lambda alone without EFS
Virus definitions	Updated daily automatically via a scheduled task
If a virus is found	File held in quarantine folder. Slack alert sent to Unloq team. File never made available.
Scan speed	Under 60 seconds per file
Extra cost	EFS storage approximately GBP 5-15 per month depending on definition file size
Effort to build	1-2 days once EFS is approved and provisioned

9.2 Social Login — Google and Microsoft

Status: Awaiting OAuth Credentials from Satyen
The backend is fully built and ready for Google and Microsoft login.
The frontend registration page has placeholder buttons.
Blocked on: Satyen must register vault.unloq.co as an OAuth app in Google and Microsoft portals.
Once credentials are provided, estimated 1 day to wire up and test.

Item	Detail
What is needed from Satyen	OAuth Client ID and Client Secret from Google Cloud Console and Microsoft Azure AD

© 2026 Unloq Solutions LtdInternal — Confidential

Google setup	Register app at console.cloud.google.com — set redirect URI to https://vault.unloq.co/oauth/callback
Microsoft setup	Register app at portal.azure.com — set redirect URI to https://vault.unloq.co/oauth/callback
What is already done	Backend handles Google and Microsoft sign_up_channel, approval, and welcome email
What is left to build	Wire up frontend buttons in Register page with Cognito federated sign-in
Benefit	Users can log in with their existing Google or Microsoft work account — no separate password

9.3 Future Improvements

Feature	Priority	Description
Per-tenant encryption keys	Medium	Allow clients with compliance requirements to have their own dedicated KMS key
S3 Access Points	Medium	Stronger tenant isolation at scale — recommended when reaching 20+ tenants
Database query optimisation	Medium	Add index on tenant ID field to speed up lookups as tenant count grows
SSO / SAML federation	Low	Enterprise clients on Okta or Azure AD could log in via their company identity provider
Per-client VPC isolation	Low	Full network isolation per client — for highest-security requirements
File usage analytics	Low	Admin view of upload statistics and storage usage per tenant

© 2026 Unloq Solutions LtdInternal — Confidential